

BACKLOG.md — DocID Platform

Backlog organizado por fases. Cada fase é um entregável funcional e independente.
Critério de prioridade: P0 = bloqueante | P1 = essencial | P2 = importante | P3 = nice-to-have

Estado: Fases 1-4 completas e validadas E2E. Fase 5 maioritariamente completa (falta preview de PDF/multi-página no scanner e cache do classificador). Fase 6 — Geração Offline de Identificadores — em progresso (backend completo, desktop nativo e UI pendentes).

FASE 1 — Fundação (API Multi-tenant + Auth + RBAC)

Objectivo: API funcional com isolamento por organização, autenticação, sectores e controlo de acesso. **Entregável:** Servidor pronto para receber o cliente Tauri.

(sem alterações nesta ronda — ver secção 5.6 para correcções de segurança aplicadas posteriormente a itens aqui marcados como completos)

1.1 — Setup do Projecto

- ✓ **P0** Inicializar monorepo ((docid/apps/api, docid/apps/desktop, docid/packages/types))
- ✓ **P0** Configurar (packages/types) com tipos partilhados (tenant, user, document, identifier)
- ✓ **P0** Migrar base de dados de SQLite → PostgreSQL
- ✓ **P0** Configurar Drizzle ORM com conexão PostgreSQL
- ✓ **P0** Setup Redis (cache + BullMQ)
- ✓ **P0** Configurar variáveis de ambiente (.env) + validação com TypeBox
- ✓ **P1** Setup Swagger UI em (/docs) actualizado com novos endpoints

1.2 — Schema da Base de Dados

- ✓ **P0** Tabela (organizations) (tenants)
- ✓ **P0** Tabela (sectors)
- ✓ **P0** Tabela (users)
- ✓ **P0** Tabela (roles) (system + custom)
- ✓ **P0** Tabela (role_permissions)
- ✓ **P0** Tabela (user_roles)
- ✓ **P0** Tabela (categories) (seed com 45 categorias)
- ✓ **P0** Tabela (identifiers) (com campo (origin: digital | physical))
- ✓ **P0** Tabela (documents)
- ✓ **P0** Tabela (document_shares)
- ✓ **P0** Tabela (approvals)
- ✓ **P0** Tabela (audit_logs)
- ✓ **P0** Configurar Row Level Security (RLS) no PostgreSQL para todas as tabelas com

`tenant_id` — ver 5.6, mecanismo original tinha falha de isolamento sob concorrência, corrigido

✓ P0 Criar índices: `tenant_id`, `sector_id`, `identifier`, `status`, `created_at`

✓ P1 Migration inicial com Drizzle Kit

1.3 — Middleware

✓ P0 Middleware de autenticação JWT (`auth.middleware.ts`)

✓ P0 Middleware de tenant (`tenant.middleware.ts`) — reescrito em 5.6, ver detalhes

✓ P0 Middleware de permissões (`rbac.middleware.ts`)

1.4 — Módulo Auth

✓ P0 `POST /auth/login`

✓ P0 `POST /auth/refresh`

✓ P0 `POST /auth/logout`

✓ P1 `GET /auth/me`

✓ P1 `PATCH /auth/me/password`

✓ P1 `PATCH /auth/me/notifications-preferences` (novo — Fase 5.5)

☐ P2 `POST /auth/forgot-password`

☐ P2 `POST /auth/reset-password`

1.5 — Módulo Organizações (Tenants)

✓ P0 `POST /tenants`

✓ P0 `GET /tenants/me`

✓ P1 `PATCH /tenants/me`

✓ P1 `PATCH /tenants/me/identifier-prefix`

☐ P2 `GET /tenants/me/stats`

1.6 — Módulo Sectores

✓ P0 `POST /sectors`

✓ P0 `GET /sectors`

✓ P0 `GET /sectors/:id`

✓ P0 `PATCH /sectors/:id`

✓ P0 `PATCH /sectors/:id/supervisor`

✓ P1 `DELETE /sectors/:id` — tratamento de erro de FK adicionado em 5.6

✓ P1 `GET /sectors/:id/members`

1.7 — Módulo Utilizadores

✓ P0 `POST /users`

✓ P0 `GET /users`

✓ P0 `GET /users/:id`

✓ P0 `PATCH /users/:id`

- ✓ **P0** `PATCH /users/:id/sector`
- ✓ **P1** `DELETE /users/:id`
- ✓ **P1** `POST /users/:id/roles`
- ✓ **P1** `DELETE /users/:id/roles/:roleId`

1.8 — Módulo Roles & Permissões

- ✓ **P0** Seed roles de sistema
- ✓ **P0** `GET /roles`
- ✓ **P1** `POST /roles`
- ✓ **P1** `PATCH /roles/:id/permissions`
- ✓ **P1** `DELETE /roles/:id`
- ☐ **P2** `GET /roles/:id/users`

1.9 — Migrar Módulos Existentes para Multi-tenant

- ✓ **P0** Todos os itens desta secção — sem alteração
-

FASE 2 — Desktop Base (App Tauri)

| **Objectivo:** Aplicação desktop funcional para as operações principais (online).

2.1 — Setup Tauri

- ✓ **P0** Inicializar projecto Tauri v2, Vite + React + TypeScript
- ✓ **P0** Configurar TailwindCSS — `shadcn/ui` não foi adoptado; UI usa componentes Tailwind próprios (`docid-ui.tsx`)
- ✓ **P0** Configurar react-router-dom v6
- ✓ **P0** Configurar Zustand
- ✓ **P0** Configurar serviço HTTP — **consolidado numa única instância via** `infrastructure/di/container.ts`, ver 5.6
- ✓ **P0** Configurar `tauri-plugin-sql` (SQLite local)
- ✓ **P0** Configurar `tauri-plugin-fs`
- ✓ **P1** Configurar `@tauri-apps/plugin-dialog` (*diálogo nativo de ficheiro/pasta, necessário para upload nativo e watcher*)
- ☐ **P1** Configurar `tauri-plugin-notification`
- ☐ **P1** Configurar `tauri-plugin-updater`

2.2 — Autenticação (UI)

- ✓ **P0** Ecrã de login
- ✓ **P0** Persistência de sessão — token via `tauri-plugin-store`, **encriptado com AES-GCM** (`SecureStorageAdapter`)
- ✓ **P0** Refresh automático de JWT
- ✓ **P0** Logout + limpeza de sessão
- ✓ **P1** Hidratação do perfil via `GET /auth/me` no arranque (*antes só decodificava o JWT*)

localmente — corrigido)

☐ P1 Ecrã de "Esqueci a password"

2.3 — Layout & Navegação

☒ P0 Layout principal + sidebar + header

☒ P0 Sidebar com navegação por módulos, incluindo Digitalizar

☒ P0 Header com utilizador, organização, notificações, logout

☒ P1 Badge de fila offline no header

☒ P1 Tema claro/escuro (*Settings* → *Aparência*)

2.4 — Dashboard

☒ P0 Cards de estatísticas

☐ P1 Gráfico de actividade

☐ P1 Lista de documentos recentes

☐ P1 Lista de aprovações pendentes no dashboard

☐ P2 Widget de fila offline no dashboard

2.5 — Módulo Identificadores (UI)

☒ P0 Todos os itens desta secção — implementados (`Identifiers.tsx`)

☐ P1 Visualização do histórico de eventos do identificador

2.6 — Módulo Documentos (UI)

☒ P0 Listar, upload, detalhe, download — implementados (`Documents.tsx`)

☒ P1 Indicador de origem digital/físico

☐ P2 Pré-visualização inline de PDFs

2.7 — Contratos & Candidaturas como Perfis (UI)

☐ Sem alteração — não abordado nesta ronda de trabalho.

2.8 — Gestão de Utilizadores & Sectores (UI)

☒ P1 Todos os itens principais — implementados (`Users.tsx`, `Sectors.tsx`)

☐ P2 Página de perfil dedicada por utilizador (fora do próprio perfil)

☐ P2 Transferir utilizador entre sectores — via UI de edição, sem fluxo dedicado

FASE 3 — Offline Sync

┆ **Objectivo:** Utilizadores podem fazer upload de ficheiros sem conexão.

3.1 — Fila Local (Tauri / Rust)

☒ P0 Todos os itens desta secção

☒ P0 Bug crítico corrigido: `safe_dest_path` falhava sempre (`canonicalize()` chamado sobre um caminho ainda inexistente) — impedia todo o enfileiramento offline. Provado com teste antes/depois.

3.2 — Motor de Sync (Rust)

- ✓ **P0** Todos os itens desta secção
- ✓ **P1** Recuperação de itens presos em `(uploading)` após crash/encerramento inesperado (`(reset_stuck_items)`, corre no arranque do ciclo de sync)

3.3 — UI da Fila Offline

- ✓ **P0/P1** Todos os itens, excepto notificação nativa (pendente)

3.4 — BullMQ Server-side

- ☐ Sem alteração — não abordado nesta ronda.

FASE 4 — Workflows (Partilha + Aprovações)

Sem alterações funcionais nesta ronda — ver 5.6 para correcções de segurança aplicadas aos módulos `(approvals)` e `(documents)` (partilha).

FASE 5 — Nativo Avançado

5.1 — File System Watcher

- ✓ **P0** `(start_watcher)` / `(stop_watcher)`
- ✓ **P0** Detecção de ficheiros novos e **pré-existent**s — `(notify)` só reage a eventos futuros; foi adicionada uma varredura inicial (`(walk_files)`) no arranque do watcher para cobrir ficheiros já presentes na pasta.
- ✓ **P0** Extracção de texto (Rust): `(pdf-extract)` para PDF, leitura directa para TXT/MD/CSV. `(.docx)` continua pendente (decisão entre `(docx-rs)` ou `(quick-xml)`, documentada no código).
- ✓ **P0** Regex de detecção de identificador — formato final: `([A-Z]{1,6}-[A-Z]{2,5}-\d{4}-\d{4}-\d{3})` (o limite inferior do prefixo da organização foi corrigido de 2 para 1 carácter, para cobrir prefixos curtos permitidos pelo schema).
- ✓ **P1** Deduplicação de notificações — `(watcher_seen.json)` (path + mtime, escrita atómica) evita reprocessar o mesmo ficheiro a cada arranque da app.
- ☐ **P0** UI com as 3 opções por ficheiro detectado (Adicionar agora / mais tarde / Não pertence) — **parcial**: os eventos backend já distinguem `(identifier_found)` de `(file_detected)`, e a aba "Pastas Vigiladas" mostra um contador; falta a lista detalhada de ficheiros detectados com as 3 acções específicas.
- ✓ **P1** UI de configuração de pastas monitorizadas (`(Settings)` → "Pastas Vigiladas": listar, adicionar via diálogo nativo, remover, iniciar/parar, estado sincronizado com o backend via `(is_watcher_running)`)
- ☐ **P1** Lista de ficheiros "adicionados mais tarde" (lembretes)
- ☐ **P1** Relatório de detectados vs ignorados (além do contador simples)

5.2 — Integração Scanner

- ✓ **P0** `(list_scanners)`, `(scan_document)`, opções de resolução/modo/formato
- ✓ **P1** UI completa (`(Scanner.tsx)`): selecção de dispositivo, opções, digitalizar, download do

resultado

- ☒ **P1** Pré-visualização — só para PNG; PDF ainda sem preview
- ☐ **P1** Multi-página — adiado deliberadamente (depende de viabilidade de uma crate de renderização PDF→PNG cross-platform, ainda por confirmar)
- ☐ **P2** Integração com impressoras

5.3 — Classificação por IA

- ☒ **P0** (`POST /classifier/suggest`)
- ☒ **P0** Prompt de classificação
- ☒ **P0** UI de sugestão com barra de confiança (`ClassifierSuggestion.tsx`)
- ☒ **P0** Utilizador pode confirmar ou seleccionar categoria manualmente
- ☐ **P1** Melhorar prompt com exemplos few-shot
- ☒ **P1** Registo de feedback (`POST /classifier/feedback`), tabela (`classifier_feedback`), com validação de categoria e de posse do documento pelo tenant)
- ☐ **P2** Cache Redis de classificações — **adiado**; se implementado, a chave tem de incluir (`tenantId`) (`classifier:{tenantId}:hash:{sha256}`) para evitar partilha de cache entre organizações diferentes

5.4 — Onboarding de Organizações

- ☒ **P1** Fluxo multi-passo implementado (`Onboarding.tsx`): dados da organização com slug/prefixo auto-gerados e editáveis, administrador, confirmação → (`POST /tenants`) → redirecciona para login com aviso de sucesso (sem auto-login, por decisão explícita)
- ☒ **P1** Ecrã de configurações da organização (`Settings`) → "Organização")
- ☐ **P2** Importar utilizadores via CSV
- ☐ **P2** Convite de membros por email (não fazia parte do fluxo simplificado)

5.5 — Configurações & Preferências (UI)

- ☒ **P1** Perfil do utilizador (`Profile.tsx`)
- ☒ **P1** Configurações da organização (nome, prefixo, slug/plano read-only)
- ☒ **P1** Configuração de pastas monitoradas
- ☐ **P1** Configuração de scanner padrão (persistido) — a página Scanner permite escolher dispositivo por sessão, mas não guarda uma preferência por defeito
- ☒ **P2** Configuração de notificações — 5 toggles (`PATCH /auth/me/notifications-preferences`)
- ☒ **P2** Exportar dados da organização — auditoria (CSV, streaming) e estatísticas (JSON), ambos com rate limit de 5/hora

5.6 — Correções de Segurança e Robustez (nova secção — hardening pós-auditoria)

Itens da Fase 1 já estavam marcados como completos, mas uma auditoria de segurança revelou falhas reais de isolamento e integridade. Documentadas aqui por serem correcções a trabalho já entregue, não funcionalidade nova.

- ☒ **P0** RLS reforçado: o mecanismo original (`set_config`) fora de transacção) podia perder

isolamento sob concorrência de pool de conexões; substituído por `(withTenant())` — cada request corre dentro de uma transacção com `(SET LOCAL app.current_tenant)`, garantindo que o valor nunca escapa para outra conexão reaproveitada pelo pool.

✓ **P0** Advisory lock de geração de identificadores não protegia o `(INSERT)` (só a leitura da sequência) — corrigido para cobrir leitura + inserção na mesma transacção.

✓ **P0** Owner bypass em falta na visibilidade de identificadores — o criador de um identificador `(sector_only)` perdia acesso ao mudar de sector; corrigido, alinhado com o mesmo bypass já existente para documentos.

✓ **P0** Roles verificadas a partir do JWT (potencialmente desactualizado) em vez da base de dados em `(canResolveApproval)/(canShareDocument)` — corrigido para usar `(getFreshRoles())`, consistente com `(requireRole())`.

✓ **P1** Tratamento de erro uniforme (`(safeError())` + padrão de re-throw/rollback seguro) aplicado a todos os handlers de escrita em `(identifiers)`, `(documents)`, `(approvals)`, `(roles)`, `(sectors)`, `(users)`, `(classifier)` — antes, alguns `(try/catch)` capturavam o erro *dentro* da transacção do `(withTenant)`, mascarando falhas e permitindo commit parcial.

✓ **P1** `(DELETE /sectors/:id)` devolve erro claro em violação de FK em vez da mensagem crua do Postgres.

✓ **P1** Suite de testes de segurança e carga (`(apps/api/scripts/loadtest/)`): fuzzing de concorrência entre tenants (600 requests), exaustão de pool, rollback de `(SET LOCAL)`, bypass de `(tenantId)` malformado, contenção do advisory lock — todos confirmados sem fuga de dados entre tenants.

✓ **P2** Consolidação de `(HttpApiClient)/adapters Tauri` numa única instância via `(infrastructure/di/container.ts)`, eliminando instâncias soltas espalhadas por vários componentes.

✓ **P2** Bun adoptado oficialmente como gestor de pacotes do desktop (`(packageManager)` no `(package.json)`), após incompatibilidade do `(npm)` com a versão de Node instalada.

FASE 6 — Geração Offline de Identificadores (*nova fase, fora do plano original*)

Objectivo: permitir gerar identificadores sem ligação à internet, sem risco de duplicados entre dispositivos, respeitando a exigência legal angolana de numeração sequencial e cronológica para documentos fiscais (Decreto Presidencial 292/18 e 71/25).

Descoberta importante: nem todas as categorias têm exigência legal de sequência — só `(FAT)`, `(REC)`, `(NOT)`, `(NDB)` (confiança alta) e `(GUE)`, `(ORD)` (confiança média, por precaução) precisam do mecanismo pesado de reserva de lotes. As restantes ~36 categorias usam um caminho simplificado. **Pendente:** confirmação desta classificação por um contabilista/consultor fiscal angolano antes de produção real — isolada numa única coluna (`(categories.requiresSequential)`), corrigível sem alterar código.

6.1 — Schema (M0)

✓ **P0** Coluna `(categories.requiresSequential)` (boolean, default false)

- ✓ **P0** Coluna `organizations.identifierLeaseBatchSize` (default 50, configurável pelo `ORG_ADMIN`)
- ✓ **P0** Tabela `devices` — identidade estável de cada instalação desktop
- ✓ **P0** Tabela `identifier_leases` — lotes de sequência reservados por dispositivo (chave de alocação `tenantId + categoryId`, sem `sectorId`, consistente com `generateIdentifier` já existente)
- ✓ **P0** Tabela `identifier_release_pool` — fragmentos devolvidos e disponíveis para reaproveitamento
- ✓ **P0** Índice único parcial (`WHERE status = 'active'`) impedindo dois lotes activos simultâneos para o mesmo dispositivo+categoria
- ✓ **P0** As 3 tabelas novas adicionadas a `TABLES_WITH_TENANT` (RLS)

6.2 — Lógica de alocação no backend (M1)

- ✓ **P0** `next_free` para geração online passa a considerar lotes activos de outros dispositivos (`GREATEST(MAX(sequence), MAX(lease.endSeq))`) — sem isto, geração online podia colidir com um lote já reservado mas ainda não consumido offline
- ✓ **P0** `POST /identifiers/lease` — reserva um lote, com first-fit no pool de fragmentos devolvidos antes de estender a sequência
- ✓ **P0** `POST /identifiers/lease/:id/release` — devolve a sobra não usada ao pool
- ✓ **P0** `PATCH /devices/:id/force-release` — acção administrativa irreversível para dispositivo perdido/nunca reconectado (`ORG_ADMIN` only)
- ✓ **P0** `POST /identifiers/register-offline` — regista um identificador já gerado offline com o número exacto reservado no lote

6.3 — Caminho simplificado para categorias não-fiscais (M1.5)

- ✓ **P1** `POST /identifiers/register-offline-loose` — sem lease nem lock partilhado prévio; reutiliza `generateIdentifier()` internamente (mesma protecção de concorrência já corrigida em 5.6); **um identificador por request, sem suporte a lote** (decisão deliberada, evita reintroduzir a classe de bug de "resolver categoria por item dentro de um lote")
- ✓ **P1** Validação: rejeita se a categoria afinal tiver `requiresSequential = true`

6.4 — Testes do backend (M2)

- ✓ **P0** Concorrência de `POST /identifiers/lease` sem sobreposição de intervalos
- ✓ **P0** Geração online nunca atribui número dentro de um lote activo
- ✓ **P0** Reaproveitamento correcto do pool após `release`
- ✓ **P0** Rejeição de `register-offline` fora do intervalo do lote ou de lote alheio
- ✓ **P0** `force-release` seguido de tentativa de registo é rejeitado

6.5 — Desktop nativo (M3) — pendente

- ☐ **P0** Cache local (SQLite) de lotes activos, prefixo da organização e categorias (para montar o identificador offline sem rede)

- ☐ **P0** Comando `generate_offline_identifier` — consome lote local (categorias fiscais) ou contador local solto (restantes)
- ☐ **P0** Fila de sincronização de identificadores pendentes, um de cada vez (consistente com o motor de sync já existente)
- ☐ **P1** Renovação automática de lote perto do esgotamento

6.6 — Frontend (M4) — pendente

- ☐ **P0** `Identifiers.tsx` — caminho offline com indicação visual de número "definitivo" (fiscal, via lease) vs "provisório até sincronizar" (não-fiscal, via `register-offline-loose`)
 - ☐ **P1** `Settings` → "Organização": configurar `identifierLeaseBatchSize`
 - ☐ **P1** Gestão de dispositivos (listar, force-release com aviso de irreversibilidade)
-

Débito Técnico & Qualidade

- ☒ **P1** Testes de integração para endpoints críticos
 - ☒ **P1** Testes do motor de sync offline — **feito**: `compute_upload_outcome` (função pura), `reset_stuck_items` (crash recovery), ciclo completo sucesso/falha até `MAX_ATTEMPTS`, 30+ testes Rust no total
 - ☒ **P1** Rate limiting nos endpoints públicos — **estendido** aos novos endpoints de exportação (5/hora)
 - ☒ **P1** Sanitização de nomes de ficheiro no upload (path traversal) — também aplicado ao `attach_document_native` (Rust)
 - ☐ **P1** Logs estruturados na API (pino ou similar)
 - ☒ **P1** Health check endpoint `GET /health`
 - ☒ **P2** Documentação OpenAPI actualizada
 - ☒ **P2** Script de seed para dados de demonstração
 - ☐ **P2** Pipeline CI básica (lint + typecheck + testes)
 - ☐ **P3** Testes E2E com Playwright
-

Resumo por Fase

Fase	Foco	Estado
1	API multi-tenant + Auth + RBAC	✅ Completo (E2E validado; correcções de segurança em 5.6)
2	App Tauri (online)	✅ Completo
3	Offline sync	✅ Completo (incl. bug crítico de path corrigido, testes)
4	Partilha + Aprovações + SSE	✅ Completo
5	Scanner + IA + File Watcher + Settings	🔄 Quase completo — falta preview PDF/multi-página no scanner, cache do classificador, e a UI detalhada de 3-opções do watcher
5.6	Correcções de segurança (hardening)	✅ Completo — RLS, advisory lock, roles frescas, tratamento de erro uniforme, suite de testes de carga
6	Geração offline de identificadores	🔄 Backend completo (M0-M2); desktop nativo e UI pendentes (M3-M4); classificação legal de categorias pendente de confirmação profissional

Consultar `README.md` para visão geral do produto e arquitectura; este ficheiro é o documento vivo de estado por fase.